

# Retail POS Card Data Breach

Cyber Tabletop Exercise - Facilitator Package

Organization: NorthStar Retail Group

Scenario source: Retail Point-of-Sale Card Data Breach

Prepared from uploaded STIX 2.1 bundle

Exercise classification: Confidential - simulated scenario for training and preparedness.

Recommended duration: 90 minutes | Audience: Executive, operational, technical, legal/compliance, communications, store operations, and payment operations

# 1. Introduction

This tabletop exercise simulates a payment card data compromise at a retail organization following the deployment of memory-scraping malware within the Point-of-Sale environment. The scenario is designed to test incident escalation, technical containment, payment processor coordination, PCI-related response, customer impact assessment, communications, and recovery governance.

The exercise is discussion-based. Participants should respond based on their current roles, processes, authorities, and available tools. The facilitator should encourage realistic decision-making rather than perfect hindsight.

## Source STIX interpretation

- Victim organization: NorthStar Retail Group (retail).
- External stakeholder: Payment Processor (financial-services).
- Target infrastructure: Point-of-Sale Environment - Retail payment terminals and back-office systems processing in-store card transactions.
- Threat actor: Card Harvesting Crew (crime-syndicate).
- Malware: LaneScrape - Memory-scraping malware used to harvest payment card data from POS terminals.
- Primary threat behaviors: POS memory scraping and exfiltration of stolen card data over attacker-controlled infrastructure.

## 2. Exercise Scope

- In scope: incident detection, escalation, containment of affected POS terminals, payment processor engagement, PCI-related incident response, legal/regulatory assessment, communications, business continuity for in-store payments, forensic evidence handling, eradication, safe restoration, and post-incident reporting.
- Out of scope: live technical testing, actual disruption to payment systems, attribution beyond the simulated threat actor, and review of unrelated corporate systems.
- Assumption: the organization has multiple store locations using centrally managed POS terminals and depends on a third-party payment processor for transaction processing.

## 3. Exercise Objectives

- Validate how fraud alerts from a payment processor are triaged and escalated to security, store operations, payment operations, legal, compliance, and executive leadership.
- Test decision-making for isolating POS terminals while maintaining safe payment acceptance through backup processes.
- Assess readiness to conduct PCI-related incident response, including evidence preservation, forensic investigation, transaction log collection, and payment brand/processor coordination.
- Evaluate internal and external communications, including customer messaging, store guidance, media posture, and regulator/payment ecosystem notifications.
- Identify improvements to detection, segmentation, POS hardening, privileged access, asset inventory, vendor coordination, and post-incident governance.

## 4. Participants and Suggested Roles

| Role                    | Primary exercise focus                                                                                     |
|-------------------------|------------------------------------------------------------------------------------------------------------|
| Executive / Crisis Lead | Business impact, risk appetite, customer trust, regulatory posture, resource prioritization.               |
| SOC / Incident Response | Triage, containment, IOC validation, evidence preservation, monitoring, eradication and recovery criteria. |
| Payment Operations      | Processor coordination, transaction continuity, settlement implications, affected store and terminal list. |

|                              |                                                                                                    |
|------------------------------|----------------------------------------------------------------------------------------------------|
| Store Operations             | Operational workarounds, frontline instructions, customer service, cash/manual fallback decisions. |
| Legal / Compliance / Privacy | PCI obligations, breach assessment, notification strategy, counsel engagement, records retention.  |
| Communications               | Internal talking points, customer communications, media holding statement, call center messaging.  |
| IT / Infrastructure          | Network segmentation, POS rebuild/reimage, endpoint management, backup payment routing.            |

## 5. Rules of Engagement

- Real incidents take priority. Participants may step out if operational responsibilities require it.
- There are no right or wrong answers; the objective is to surface assumptions, gaps, dependencies, and decision points.
- Suspend disbelief. Treat the scenario as realistic and time-bound.
- Do not fight the scenario. Ask clarifying questions, but make decisions with limited information as in a real incident.
- Avoid blame. Focus on roles, processes, decision rights, communications, and improvement opportunities.
- The facilitator may advance time, introduce new facts, or withhold information to preserve exercise realism.

## 6. Scenario Overview

NorthStar Retail Group receives fraud linkage reports from its payment processor. Several recently used cards later show fraudulent activity, and the common purchase point appears to be multiple stores operated by the retailer. Initial technical review identifies unusual encrypted outbound traffic from POS terminals. Forensic analysis later confirms the presence of LaneScrape, a memory-scraping malware family used to harvest payment card data from POS terminal memory before authorization messages are encrypted.

### Exercise assumptions

- The incident initially appears as fraud intelligence rather than an internal security alert.
- Only a subset of stores is known to be affected at the start; the full scope is uncertain.
- The payment processor requests urgent containment, transaction logs, and a PCI-related incident briefing.
- Customer data exposure is plausible but not fully confirmed until forensic scoping is complete.
- Business disruption risk is significant because disabling POS terminals affects in-store revenue and customer experience.

## 7. Proposed Exercise Agenda

| Time      | Activity                          | Purpose                                                                    |
|-----------|-----------------------------------|----------------------------------------------------------------------------|
| 0-10 min  | Welcome, objectives, rules        | Align participants on scope and expected behavior.                         |
| 10-25 min | Inject 1 - Fraud reports          | Test triage, escalation, initial impact assessment.                        |
| 25-45 min | Inject 2 - Suspicious POS traffic | Test SOC/payment operations coordination and containment options.          |
| 45-65 min | Inject 3 - Malware confirmed      | Test breach assessment, evidence, PCI response and communications.         |
| 65-80 min | Inject 4 - Processor escalation   | Test governance, external coordination, business continuity and reporting. |
| 80-90 min | Debrief and actions               | Capture strengths, gaps, owners and deadlines.                             |

## 8. Exercise Injects and Facilitation Guide

### Inject 1 - Fraud Reports

**Simulated time:** Day 1, 09:15 **Source:** Payment Processor Fraud Monitoring

**Inject statement:** The payment processor notifies the retailer of increased fraudulent card activity linked to recent purchases at several stores.

#### What participants know

- Fraud activity appears linked to purchases at several stores in the past two weeks.
- The payment processor cannot yet confirm whether the common point of purchase is the retailer or another merchant.
- No internal security alert has yet confirmed compromise.
- Store operations report normal transaction flow.

#### Discussion questions

- 1 Who owns initial triage when the first signal comes from the payment processor rather than internal monitoring?
- 2 What evidence should be requested immediately from the processor, and what can be shared back?
- 3 What internal stakeholders must be notified at this stage, and at what severity?
- 4 How will affected stores, terminals, time windows, and transaction volume be scoped?
- 5 What customer, media, or regulatory posture is appropriate before compromise is confirmed?

#### Expected actions / strong-response indicators

- Open or upgrade an incident record and assign an incident commander.
- Engage SOC/IR, payment operations, store operations, legal/compliance, privacy, communications, and relevant executives.
- Request fraud linkage details, affected BIN/card ranges if available, transaction dates, merchant IDs, terminal IDs, and processor contact path.
- Preserve POS, network, EDR, DNS, proxy, firewall, payment gateway, and transaction logs for the suspected window.
- Define preliminary severity using customer impact, payment data sensitivity, operational exposure, and external stakeholder pressure.

#### Facilitator notes

Look for whether participants recognize that fraud notifications can be an early breach indicator. Press for clear ownership, evidence requests, preservation steps, and restraint in external statements before confirmation.

## Inject 2 - Suspicious POS Traffic

**Simulated time:** Day 1, 11:30 **Source:** Network Monitoring / SOC

**Inject statement:** Network monitoring detects unusual outbound encrypted traffic from POS terminals to an external host not used by approved payment services.

### What participants know

- Outbound encrypted traffic is observed from several POS terminals to an unapproved external host.
- Traffic occurs outside normal payment authorization destinations.
- The impacted terminals are in stores previously flagged by the payment processor.
- The external host is not on an approved payment service allowlist.

### Discussion questions

- 1 Who has authority to isolate POS terminals, stores, network segments, or egress paths?
- 2 What is the threshold for disabling payment processing versus monitoring and scoping further?
- 3 How are store managers instructed without causing unnecessary alarm or evidence destruction?
- 4 What backup payment processes exist, and what risks do they introduce?
- 5 What indicators should be shared internally, with the processor, or with external response partners?

### Expected actions / strong-response indicators

- Block known suspicious destinations while preserving logs and packet metadata.
- Isolate affected POS terminals or store segments using pre-approved containment procedures.
- Validate payment processor endpoints and approved outbound destinations.
- Collect volatile evidence where possible before reimaging or powering down devices.
- Activate business continuity playbooks for affected stores, including validated backup payment routes or controlled cash-only operations.

### Facilitator notes

Challenge the group on business-versus-security tradeoffs. A strong response distinguishes tactical blocking from full containment and documents who can approve each action.

## Inject 3 - Malware Confirmed

**Simulated time:** Day 1, 15:00 **Source:** Forensic Analysis

**Inject statement:** Forensic analysis confirms memory-scraping malware on multiple POS terminals. Cardholder data may have been collected before authorization messages were encrypted.

### What participants know

- Forensics identify LaneScape on multiple POS terminals.
- The malware appears designed to scrape cardholder data from memory before transaction data is encrypted.
- Scope is still expanding; some stores may have older POS images or weaker segmentation.
- The processor asks whether the retailer can identify first compromise date, affected stores, affected terminals, and exposed transaction volume.

### Discussion questions

- 1 What evidence is required to determine whether cardholder data was actually exfiltrated?
- 2 Who decides whether this is a reportable payment card incident, privacy incident, or both?
- 3 What is the communication plan for executives, store leadership, customer care, processor contacts, acquiring bank, and external counsel?
- 4 How will the team balance eradication with evidence preservation?
- 5 What criteria must be met before terminals or stores are returned to service?

### Expected actions / strong-response indicators

- Engage qualified forensic support if required by payment ecosystem obligations or internal policy.
- Preserve forensic images, malware samples, logs, and chain-of-custody records.
- Identify affected merchant IDs, store locations, terminal IDs, transaction date ranges, and potential cardholder data elements exposed.
- Draft legal/regulatory and payment ecosystem notification decision records.
- Prepare customer support, media holding statements, and internal talking points while avoiding premature breach conclusions.

### Facilitator notes

This is the key decision point. Push participants to separate confirmed malware presence from confirmed exfiltration while still acting with urgency due to payment card risk.

## Inject 4 - Payment Processor Escalation

**Simulated time:** Day 2, 09:00 **Source:** Payment Processor / PCI Escalation

**Inject statement:** The payment processor requests immediate containment actions, transaction logs, affected store list, and a PCI-related incident response briefing.

### What participants know

- The processor requests immediate containment status, transaction logs, affected store list, and a PCI-related briefing.
- Some stores remain on backup processes, generating customer wait times and revenue impact.
- Executives request a clear public posture and estimated recovery timeline.
- The SOC reports no new outbound connections after containment, but forensics have not fully completed root-cause analysis.

## Discussion questions

- 1 What information can be shared with the processor now, and what requires legal review?
- 2 What is the decision process for public communication and customer notification if the scope remains uncertain?
- 3 What recovery gates must be met before reconnecting or rebuilding POS systems?
- 4 What compensating controls should remain in place after stores resume normal payment operations?
- 5 What lessons must be captured for PCI compliance, segmentation, POS monitoring, and vendor/processor coordination?

## Expected actions / strong-response indicators

- Deliver a structured incident briefing with confirmed facts, assumptions, containment status, open questions, and next update cadence.
- Maintain executive crisis governance until containment, customer impact assessment, and recovery criteria are satisfied.
- Reimage or replace affected POS terminals from trusted gold images; rotate credentials and certificates as needed.
- Increase monitoring of POS egress, file integrity, EDR alerts, DNS/proxy logs, and payment-related exceptions.
- Prepare post-incident report, lessons learned, control improvements, and regulator/payment ecosystem follow-up actions.

## Facilitator notes

Assess whether the team can communicate under uncertainty. Look for disciplined facts, clear owners, and decisions recorded against legal, business, and technical constraints.

## 9. Key Decision Points

| Decision point                   | Options to explore                                                                                         | Good evidence of maturity                                                                                         |
|----------------------------------|------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Incident severity and escalation | Watch-and-monitor, operational incident, cyber incident, crisis activation.                                | Severity is tied to payment data sensitivity, fraud linkage, store impact, and external stakeholder requirements. |
| Containment scope                | Block destination only, isolate terminals, isolate stores, disable payment routes, move to backup process. | Decision owner, business impact and evidence preservation are documented before disruptive action.                |
| Customer and public posture      | No statement, holding statement, targeted notification, broad customer notification.                       | Legal, privacy, communications and executive stakeholders align on facts, thresholds and approval path.           |
| PCI / processor response         | Informal update, formal incident briefing, forensic engagement, regulator/payment brand coordination.      | Processor requests are logged, tracked and answered with confirmed facts and protected assumptions.               |
| Recovery approval                | Reconnect after scan, rebuild from gold image, staged store restoration, continued heightened monitoring.  | Recovery gates include eradication, credential rotation, clean images, monitoring and business sign-off.          |

## 10. Technical and Business Impacts

### Technical impacts

- Potential compromise of POS terminal memory and exposure of payment card track-equivalent data.
- Unauthorized outbound encrypted traffic from terminals to external infrastructure.
- Need for forensic acquisition, malware analysis, network egress review, POS image validation, credential rotation, and segmentation validation.
- Possible compromise window across multiple stores until terminal-level and transaction-level scoping is complete.

### Business impacts

- Customer trust and brand impact if card data exposure is confirmed or strongly suspected.
- Store disruption from terminal isolation, reimaging, or fallback payment processes.
- Processor, acquiring bank, card brand, PCI, legal, privacy, insurance, and regulator coordination workload.
- Potential revenue loss, increased customer service volume, chargeback/fraud management, and remediation costs.

## 11. Debrief and Lessons Learned

Use the final 10 minutes to capture decisions, gaps, action owners, and due dates. The facilitator should distinguish immediate remediation actions from longer-term program improvements.

- What worked well in detection, escalation, communications, and containment?
- Where were decision rights unclear?
- Were payment operations, store operations, SOC, legal/compliance, privacy, communications, and executives synchronized?
- Were backup payment processes documented, tested, secure, and acceptable for customer experience?
- What logs, asset inventories, segmentation controls, or runbooks were missing or incomplete?
- What changes should be made to POS monitoring, egress allowlisting, malware prevention, forensic readiness, and PCI incident response?



# 12. Facilitator Evaluation Sheet

Suggested confidence scale: 1 = not confident, 2 = slightly confident, 3 = somewhat confident, 4 = fairly confident, 5 = completely confident.

| Capability                                                              | Rating (1-5) | Evidence / observation |
|-------------------------------------------------------------------------|--------------|------------------------|
| Fraud alerts are triaged and escalated rapidly.                         |              |                        |
| POS asset inventory supports store, terminal and merchant ID scoping.   |              |                        |
| SOC can identify and contain suspicious POS egress.                     |              |                        |
| Payment processor engagement path is known and documented.              |              |                        |
| PCI-related incident response roles and evidence needs are understood.  |              |                        |
| Business continuity options for affected stores are safe and practical. |              |                        |
| Legal, privacy, compliance and communications decision path is clear.   |              |                        |
| Recovery criteria are documented before POS systems return to service.  |              |                        |
| Post-incident reporting and lessons learned have owners and deadlines.  |              |                        |

## 13. MITRE ATT&CK; Mapping

The STIX bundle explicitly identifies the following ATT&CK; techniques. Additional tactics are included as exercise context where the scenario logically exercises defender decision-making; they should be validated against internal threat intelligence before use in detection engineering.

| Tactic                       | Technique                               | ID               | Scenario representation                                                                         | Discussion / detection focus                                                       |
|------------------------------|-----------------------------------------|------------------|-------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| Collection                   | Input Capture                           | T1056            | POS memory scraping collects card data before authorization messages are encrypted.             | Memory inspection, endpoint telemetry, POS hardening, least functionality.         |
| Exfiltration                 | Exfiltration Over C2 Channel            | T1041            | Stolen card data is transmitted to attacker-controlled infrastructure over an outbound channel. | Egress allowlisting, proxy/DNS/firewall logs, anomalous destination monitoring.    |
| Command and Control          | Encrypted Channel                       | Contextual       | Unusual encrypted outbound traffic from POS terminals to an unapproved host.                    | Approved destination baselines, TLS inspection policy, suspicious beacon patterns. |
| Impact / Business Disruption | Service interruption due to containment | Exercise control | Terminals may be isolated or stores moved to backup payment processes.                          | Business continuity, decision authority, recovery gating.                          |

## 14. Glossary

| Term          | Meaning                                                                                                           |
|---------------|-------------------------------------------------------------------------------------------------------------------|
| POS           | Point-of-Sale terminals and supporting retail payment systems.                                                    |
| PCI           | Payment Card Industry obligations and incident response expectations related to cardholder data environments.     |
| SOC           | Security Operations Center responsible for monitoring, triage and technical response coordination.                |
| IOC           | Indicator of Compromise such as suspicious domains, IP addresses, file hashes, process names or network patterns. |
| Egress        | Outbound network traffic leaving a host, store network or enterprise environment.                                 |
| Containment   | Actions taken to stop further attacker activity while preserving evidence and managing business impact.           |
| Eradication   | Removal of malware, attacker access, persistence, compromised credentials and unsafe configurations.              |
| Recovery gate | A documented condition that must be satisfied before reconnecting, rebuilding or restoring systems.               |